Threat and Vulnerability Management Standard

From the Office of the Chief Information Officer, State of Minnesota

Version: 1.10
Effective Date: 1/1/2016
Revised: 8/6/2025
Approved: John Israel, State of MN Chief Information Security Officer **Date:** 2/27/2026

Standard Statement

This standard sets the baseline requirements for the State of Minnesota to identify, prioritize, and address information security threats and vulnerabilities.

Employees must abide by the terms of this standard. Employees who violate this standard may be subject to discipline, up to and including discharge.

Table 1. Threat and Vulnerability Management Controls

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
1	Threat and Vulnerability Monitoring	Monitor reputable outside sources for applicable vendor security alerts, threat intelligence, advisories, and directives to identify security vulnerabilities in State systems.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
2	Vulnerability Scanning	Perform internal and external network level vulnerability scanning on all systems: • Using privileged credentials for internal scans. • At least monthly and when new vulnerabilities potentially affecting the systems are identified and reported. • Prior to production deployment. • Upon any significant change. Scanning procedures must demonstrate the breadth and depth of coverage of information system components scanned and vulnerabilities checked. A Payment Card Industry (PCI) Approved Scanning Vendor (ASV) must be used for external scans of systems in scope for PCI Data Security Standards (DSS).	Low Moderate High
3	Current Vulnerabilities	Vulnerability scanning software must be capable of detecting common vulnerabilities, as identified in the National Vulnerabilities Database (NVD). Vulnerability scanning definition files must be updated at least weekly.	Low Moderate High
4	Application Vulnerability Scanning	Perform application vulnerability scans on all Internet facing-applications: • Prior to production deployment. • At least annually or when new vulnerabilities potentially affecting the applications are identified and reported. • Upon any significant change.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
5	Penetration Testing	Perform network and application-level penetration testing on systems in scope for PCI DSS, ARC-AMPE, or IRS Pub. 1075 at least annually and after any significant changes. The penetration test must follow a methodology that: • Is based on industry-accepted penetration testing approaches (for example, NIST SP800-115). • Includes coverage for the entire perimeter of in scope systems and other critical systems. • Includes testing from both inside and outside the network. • Includes testing to validate any segmentation/isolation and scope-reduction controls. • Defines application-layer penetration tests to include, at a minimum, the OWASP top 10. • Defines network-layer penetration tests to include components that support network functions as well as operating systems. • Includes review and consideration of threats and vulnerabilities experienced in the last 12 months. • Specifies retention of penetration testing results and remediation activities results.	High
6	Vulnerability Risk Ranking	Information security vulnerabilities impacting the organization must be analyzed for likelihood and impact to the organization and ranked into four Severity categories: • Severity 1: Vulnerabilities that pose the highest risk to State systems or data and require immediate attention. • Severity 2: Vulnerabilities that pose high risk to State systems or data. • Severity 3: Vulnerabilities that pose a moderate or indirect risk to State systems or data. • Severity 4: Vulnerabilities that only expose non-critical system information.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
7	Notification	Promptly notify system owners and other impacted groups of relevant information security threats and vulnerabilities and their risk rating and significant changes.	Low Moderate High
8	Remediation and Mitigation	Remediate or mitigate vulnerabilities identified (via scanning, penetration test, vendor alert, etc.) as follows: • Severity 1: Within 7 days of discovery / notification or as directed by the State Chief Information Security Officer (CISO) or delegate. • Severity 2: Within 30 days of discovery / notification. • Severity 3: Within 90 days of discovery / notification. • Severity 4: Within 180 days of discovery / notification. Once remediated or mitigated, a rescan/retest must be performed to validate the remediation/mitigation.	Low Moderate High
9	Configuration Compliance Scanning	Configuration compliance scanning must be performed: • At least monthly • Against MNIT Enterprise approved standards • Against Federal and industry standards as required by the authoritative entity	High
10	Web Application Firewall	Web application firewall technology must be used for internet facing web sites and applications that meet any of the following criteria: • Citizen focused (e.g., mn.gov) • Deemed priority 1 or priority 2 systems • Require a user to log in • Employee focused (e.g., self-service) • Subject to PCI requirements • Have known vulnerabilities that cannot be resolved within the requirements of this standard • Use technology no longer supported by the vendor	Low Moderate High

Reason for the Standard

This standard ensures that information security risks to State data are identified and addressed in a timely manner and that leadership has the information needed to make informed, risk-based decisions.

Roles & Responsibilities

- Employees, Vendors, and Contractors
    - Be aware of and follow relevant information security policies, standards, and procedures.
    - Ensure information security is incorporated into processes and procedures.
    - Ensure contract language with vendors and contractors includes required information security controls.
    - Consult with information security staff on the purchase and procurement of information technology systems or services.
    - Contact information security staff or email GRC@state.mn.us with questions about the information security policies, standards, or procedures.
- Supervisors and Managers
    - Ensure employees and contractors are proficient in the information security policies, standards, and procedures that are relevant to their role.
    - Hold employees accountable for following the information security policies, standards, and procedures.
- Information Technology Personnel
    - Apply appropriate controls to the design, operation and maintenance of systems, processes, and procedures in conformance with the information security policies, standards, and procedures.
- Information Security Personnel
    - Develop, maintain, and assess compliance with the information security policies, standards, and procedures.
    - Develop, maintain, and implement a comprehensive information security program.
    - Provide training on information security policies, standards, and procedures.
    - Assist agencies and personnel with understanding and implementing information security policies, standards, and procedures.
    - Notify appropriate personnel of applicable threats, vulnerabilities and risks to State data or systems.
- Agency Data Practices Personnel
    - Assist agencies and personnel with questions on proper data use, collection, storage, destruction, and disclosure.

Applicability

This standard applies to all departments, agencies, offices, councils, boards, commissions, and other entities in the executive branch of Minnesota State Government.

Related Information

Information Security and Risk Management Program Policy

Data Protection Categorization Standard

Threat and Vulnerability Management Policy

State Standards and Authoritative Source Cross Mapping

Glossary of Information Security Terms

History

Table 2. Version History

Version	Description	Date
1.0	Initial Release	4/21/2015
1.1	Added Compliance Enforcement Date	12/29/2015
1.2	Updated Compliance Enforcement Date	12/20/2016
1.3	Updated Compliance Enforcement Date	10/22/2017
1.4	Scheduled Document Refresh	3/10/2020
1.5	Scheduled Document Refresh	11/1/2021
1.6	Added two new controls; changed patching requirement for severity 4 vulnerabilities	10/1/2022
1.7	Modified remediation timeline for severity 4 vulns; updated version number and revision date	10/1/2023
1.8	Added enforcement language; updated requirements for pen testing; updated version and revision date	12/2/2024
1.9	Limited scope for pen testing to specific regulated data systems	8/6/2025

Version	Description	Date
1.10	Replaced outdated MARS-E reference with ARC-AMPE	1/12/2026

Contact

GRC@state.mn.us